Содержание

1. Описание объекта защиты информации.....2

1.1. Сущность объекта.....2

1.2. Назначение объекта.....3

1.3. Актуальность объекта.....4

2. Анализ защищенности объекта.....4

2.1. Актуальные виды угроз.....4

2.2. Характер происхождения угроз.....6

2.3. Источники появления угроз.....7

3. Виды и модель нарушителя.....7

3.1. Потенциально возможные злоумышленники.....7

3.2. Модель нарушителя по структуре Приложения 3.....8

4. Дополнение моделирования угроз матрицами MITRE ATT&CK.....10

Заключение.....11

Введение

Цель лабораторной работы - описать и оценить объект защищаемой информации, выделить актуальные угрозы безопасности информации, определить возможных нарушителей и показать, каким образом моделирование угроз по методике ФСТЭК России может быть дополнено анализом по матрицам MITRE ATT&CK.

В качестве объекта защиты выбрана информационная система ИП «Продовольственный магазин». Рассматривается учебная модель небольшого продовольственного магазина индивидуального предпринимателя, который использует онлайн-кассу, товароучетную систему, банковский эквайринг, личные кабинеты или форму предварительного заказа, программу лояльности и рабочие места сотрудников.

Граница оценки включает компоненты, через которые обрабатываются персональные данные клиентов, сведения о заказах, учетные данные сотрудников, коммерческая информация о ценах и поставщиках, фискальные данные, журналы событий и резервные копии. Полные реквизиты банковских карт в системе магазина не хранятся: обработка платежей выполняется на стороне банка-эквайера.

При выполнении работы использованы задание лабораторной работы, Методика оценки угроз безопасности информации ФСТЭК России от 5 февраля 2021 г., рекомендуемая структура модели угроз из Приложения 3, банк данных угроз безопасности информации ФСТЭК России и база знаний MITRE ATT&CK Enterprise.

1. Описание объекта защиты информации

1.1. Сущность объекта

Информационная система ИП «продовольственный магазин» представляет собой совокупность программных, технических и организационных средств, обеспечивающих продажу продуктов питания, учет

товара, оформление чеков, работу с поставщиками, взаимодействие с клиентами и подготовку отчетности владельца ИП.

В состав объекта входят кассовый компьютер или POS-терминал, онлайн-касса, терминал эквайринга, рабочие места сотрудников, локальная сеть, Wi-Fi, товароучетная система, база данных клиентов программы лояльности, сайт или форма заказа, средства резервного копирования и внешние интеграции с банком, оператором фискальных данных, поставщиками и сервисами уведомлений.

Таблица 1 - Основные активы объекта защиты

Актив	Назначение	Критичные свойства
Кассовый узел и онлайн-касса	оформление продаж, передача фискальных данных оператору фискальных данных, печать чеков	целостность, доступность
Товароучетная система	учет остатков, цен, поставок, списаний и инвентаризации	целостность, доступность, конфиденциальность
База клиентов и программа лояльности	накопительные скидки, история покупок, контакты для доставки и уведомлений	конфиденциальность, целостность
АРМ кассира, товароведа, бухгалтера и владельца ИП	операционная работа сотрудников и управление магазином	конфиденциальность, целостность, доступность
Сайт или форма заказа с доставкой	прием предварительных заказов, обратная связь, публикация каталога	доступность, целостность, конфиденциальность
Сетевая инфраструктура и Wi-Fi	связь касс, рабочих мест, эквайринга, ОФД, банка и облачных сервисов	доступность, конфиденциальность
Резервные копии и журналы событий	восстановление учета и расследование инцидентов	целостность, конфиденциальность, доступность

1.2. Назначение объекта

Назначение объекта - обеспечить непрерывное выполнение торговых операций продовольственного магазина: продажу товаров на кассе, прием безналичных платежей, передачу фискальных данных, учет остатков, прием поставок, списание просроченной продукции, формирование отчетов и обслуживание покупателей по программе лояльности.

Система также поддерживает управленческие процессы ИП: контроль выручки, закупочные решения, сверку расчетов с поставщиками, анализ спроса, обработку обращений покупателей и восстановление учета после сбоев.

1.3. Актуальность объекта

Актуальность защиты определяется тем, что даже небольшой продовольственный магазин зависит от доступности кассового узла, корректности товарных остатков и сохранности клиентских данных. Нарушение работы кассы или товароучетной системы приводит к остановке продаж, ошибкам в отчетности, невозможности корректно списывать товар и выполнять требования законодательства о применении контрольно-кассовой техники.

С точки зрения конфиденциальности наиболее значимы персональные данные клиентов, сведения о покупках, контактные данные для доставки, учетные записи сотрудников, договоры и цены поставщиков. С точки зрения целостности критичны цены, остатки, чеки, фискальные операции, скидки и права доступа. С точки зрения доступности критичны касса, эквайринг, локальная сеть, Интернет-канал и резервное восстановление.

2. Анализ защищенности объекта

2.1. Актуальные виды угроз

Для объекта выделены угрозы, применимые к кассовому узлу, товароучетной системе, рабочим местам сотрудников, сайту заказа, локальной сети, каналам связи и данным клиентов. Перечень сформирован по банку данных угроз безопасности информации ФСТЭК России; для лабораторной работы отобрано 23 угрозы, что превышает минимальное требование задания - не менее 20 угроз.

Таблица 2 - Актуальные угрозы безопасности информации

№	Код	Наименование угрозы	Характер происхождения	Источник	Объект воздействия / последствие
1	УБИ.006	Угроза внедрения кода или данных	антропогенная, преднамеренная	внешний нарушитель, разработчик, пользователь	сайт заказа, API, товароучетная база; нарушение целостности и конфиденциальности
2	УБИ.007	Угроза воздействия на программы с высокими привилегиями	антропогенная, преднамеренная	внешний нарушитель, администратор	сервер приложения, кассовое ПО, ОС; повышение привилегий
3	УБИ.008	Угроза восстановления и (или) повторного использования аутентификационной информации	антропогенная, преднамеренная	внешний нарушитель, бывший сотрудник	учетные записи кассиров, товароведа, администратора; НСД
4	УБИ.012	Угроза деструктивного изменения конфигурации или среды окружения программ	антропогенная, преднамеренная	администратор, подрядчик, вредоносное ПО	настройки кассового узла, роутера, сервера учета; отказ или обход защиты
5	УБИ.014	Угроза длительного удержания вычислительных ресурсов пользователями	антропогенная, преднамеренная	внешний нарушитель, бот-сеть	сайт заказа, сервер учета; снижение доступности
6	УБИ.015	Угроза доступа к защищаемым файлам с использованием обходного пути	антропогенная, преднамеренная	внешний нарушитель	файлы конфигурации, выгрузки, резервные копии; раскрытие секретов
7	УБИ.016	Угроза доступа к локальным файлам сервера при помощи URL	антропогенная, преднамеренная	внешний нарушитель	локальные файлы web-сервера; раскрытие ключей, логов, дампов
8	УБИ.017	Угроза доступа, перехвата или изменения HTTP cookies	антропогенная, преднамеренная	внешний нарушитель, вредоносное ПО	сессии личного кабинета и админ-панели; захват учетной записи
9	УБИ.019	Угроза заражения DNS-кеша	антропогенная, преднамеренная	внешний нарушитель	АРМ сотрудников и клиентов; перенаправление на фишинговый ресурс
10	УБИ.022	Угроза избыточного выделения оперативной памяти	антропогенная, преднамеренная	внешний нарушитель	сервер приложения или товароучетной системы; отказ в обслуживании
11	УБИ.023	Угроза изменения компонентов информационной (автоматизированной) системы	антропогенная, преднамеренная	администратор, подрядчик, вредоносное ПО	кассовое ПО, сервер учета, модули интеграций; внедрение закладок
12	УБИ.028	Угроза использования альтернативных путей доступа к ресурсам	антропогенная, преднамеренная	внешний нарушитель, внутренний пользователь	административные интерфейсы, удаленный доступ; обход штатной авторизации
13	УБИ.030	Угроза использования информации идентификации и аутентификации, заданной по умолчанию	антропогенная, преднамеренная	внешний нарушитель, подрядчик	роутер, CMS, кассовое оборудование; НСД
14	УБИ.031	Угроза использования механизмов авторизации для повышения привилегий	антропогенная, преднамеренная	клиент, кассир, внешний нарушитель	личный кабинет, кассовое ПО, админ-панель; получение чужих прав
15	УБИ.033	Угроза использования слабостей кодирования входных данных	антропогенная, преднамеренная	внешний нарушитель	формы заказа, поиск товаров, API; SQL/NoSQL-инъекции, XSS
16	УБИ.034	Угроза использования слабостей протоколов сетевого или локального обмена данными	антропогенная, преднамеренная	внешний нарушитель, поставщик связи	локальная сеть магазина, Wi-Fi, VPN; перехват или подмена данных
17	УБИ.036	Угроза исследования механизмов работы программы	антропогенная, преднамеренная	внешний нарушитель, конкурент	сайт, API, мобильная форма заказа; подготовка целевой атаки

Таблица 2 - Актуальные угрозы безопасности информации (продолжение)

№	Код	Наименование угрозы	Характер происхождения	Источник	Объект воздействия / последствие
18	УБИ.037	Угроза исследования приложения через отчеты об ошибках	антропогенная, преднамеренная	внешний нарушитель	страницы ошибок, журналы web-приложения; раскрытие версий и путей
19	УБИ.046	Угроза нарушения процедуры аутентификации субъектов виртуального информационного взаимодействия	антропогенная, преднамеренная	внешний нарушитель, вредоносное ПО	личный кабинет, удаленный доступ, интеграции; НСД
20	УБИ.067	Угроза неправомерного ознакомления с защищаемой информацией	антропогенная, преднамеренная	кассир, товаровед, администратор, внешний нарушитель	ПДн клиентов, заказы, цены поставщиков, отчеты; утечка
21	УБИ.068	Угроза неправомерного или некорректного использования интерфейса взаимодействия с приложением	антропогенная, преднамеренная или непреднамеренная	клиент, кассир, внешний нарушитель	публичный сайт, кассовое ПО, личный кабинет; нарушение бизнес-логики
22	УБИ.069	Угроза неправомерных действий в каналах связи	антропогенная, преднамеренная	внешний нарушитель, поставщик услуг связи	сетевой трафик между магазином, банком, ОФД и облаком; перехват, подмена, блокирование
23	УБИ.167	Угроза заражения компьютера при посещении неблагонадежных сайтов	антропогенная, преднамеренная	вредоносное ПО, внешний нарушитель	АРМ кассира, товароведа, бухгалтера; компрометация учетных данных

2.2. Характер происхождения угроз

Основной массив угроз имеет антропогенное происхождение, так как реализуется действиями людей или созданного ими вредоносного программного обеспечения. Для продовольственного магазина наиболее вероятны действия внешних нарушителей, сотрудников, подрядчиков, поставщиков сервисов и бывших работников.

Преднамеренные угрозы включают эксплуатацию уязвимостей сайта заказа и удаленного доступа, подбор или повторное использование паролей, фишинг сотрудников, внедрение вредоносного кода, изменение конфигурации кассового или сетевого оборудования, неправомерную выгрузку клиентской базы, DoS-воздействие на сайт или сервер учета.

Непреднамеренные угрозы связаны с ошибками персонала: неправильной настройкой прав, публикацией лишних данных, использованием слабых паролей, установкой неподтвержденного ПО на АРМ, переходом по вредоносной ссылке, ошибочным изменением цены или остатка товара.

Техногенные и инфраструктурные факторы учитываются как условия возникновения ущерба: отказ оборудования, сбой электропитания, недоступность Интернета, отказ облачного сервиса, ошибка обновления кассового ПО или товароучетной системы. Природные факторы, например пожар или затопление помещения, прямо не относятся к большинству выбранных антропогенных УБИ, но важны для доступности и восстановления.

2.3. Источники появления угроз

Таблица 3 - Источники появления угроз

Источник	Типичные проявления	Затрагиваемые объекты
Внешние нарушители	сканирование сайта, фишинг сотрудников, эксплуатация уязвимостей, DoS	сайт заказа, удаленный доступ, каналы связи
Клиенты и пользователи программы лояльности	некорректное использование интерфейса, подбор чужих бонусных данных	личный кабинет, данные заказов, бонусные операции
Кассиры, товароведы, бухгалтерия	ошибки обработки, избыточные выгрузки, нарушение регламентов доступа	касса, товароучетная система, отчеты, ПДн
Владелец ИП и администраторы	ошибочная или умышленная смена настроек, отключение контроля, копирование данных	сервер учета, сеть, резервные копии
Подрядчики и поставщики услуг	ошибки настройки, компрометация цепочки поставки, доступ к инфраструктуре	кассовое ПО, хостинг, ОФД, связь, банк-эквайер
Вредоносное ПО	кража учетных данных, шифрование файлов, скрытое удаленное управление	АРМ сотрудников, серверы, файлы
Технические и природные факторы	отказ, повреждение оборудования, сбой питания или связи	доступность кассы, сети, резервного восстановления

3. Виды и модель нарушителя

3.1. Потенциально возможные злоумышленники

При формировании перечня нарушителей использован подход Методики ФСТЭК России: нарушителями являются лица или группы лиц, которые могут реализовать угрозы путем несанкционированного доступа или воздействия на информационные ресурсы и компоненты системы. Для выбранного объекта актуальны как внешние, так и внутренние нарушители.

Таблица 4 - Потенциально возможные нарушители

Нарушитель	Категория	Уровень возможностей	Условия доступа	Вероятные цели
Внешний хакер или малая группа	внешний	Н2-Н3	штатного доступа нет; использует Интернет, сканирование, фишинг, эксплуатацию типовых уязвимостей	кража ПДн и учетных данных, доступ к админ-панели, подготовка мошенничества
Преступная группа	внешний	Н3	финансовая мотивация; может применять бот-сети, фишинг, вредоносное ПО и вымогательство	монетизация клиентской базы, блокирование продаж, шантаж
Конкурирующий магазин или посредник	внешний	Н2	действует самостоятельно или через нанятых исполнителей	получение клиентской базы, цен поставщиков, планов закупок и скидок
Авторизованный клиент программы лояльности	внутренний пользователь	Н1	имеет личный кабинет или доступ к публичному функционалу	получение чужих бонусов, заказов или персональных данных
Кассир или товаровед	внутренний пользователь	Н1-Н2	имеет доступ к кассовому ПО, части ПДн, остаткам и ценам	ошибочное или умышленное изменение данных, выгрузка клиентской базы
Бухгалтер или владелец ИП	внутренний привилегированный	Н2-Н3	имеет расширенный доступ к отчетности, банку, договорам и учетной системе	несанкционированное копирование данных, изменение отчетности
Системный администратор, обслуживающий подрядчик	поставщик/внутренний привилегированный	Н3	имеет доступ к настройкам сети, кассовому узлу, резервным копиям и удаленному администрированию	отключение контроля, скрытая выгрузка данных, изменение конфигурации
Провайдер хостинга, связи, ОФД или облачного сервиса	поставщик услуг	Н2-Н3	имеет инфраструктурный доступ в пределах договора	нарушение доступности, доступ к резервным копиям или сетевому трафику
Бывший сотрудник	внешний/внутренний при неотозванных правах	Н1-Н2	знает процессы, адреса сервисов, старые пароли, состав персонала	месть, продажа данных, обход процедур

3.2. Модель нарушителя по структуре Приложения 3

Приложение 3 к Методике ФСТЭК России задает рекомендуемую структуру модели угроз безопасности информации. Для целей лабораторной работы из этой структуры сформирована модель нарушителя: определены область действия, объект защиты, последствия, объекты воздействия, источники угроз, способы реализации и вывод об актуальных нарушителях.

Общие положения. Модель нарушителя применяется к информационной системе ИП «Продовольственный магазин» и используется для выбора актуальных угроз, связанных с обработкой персональных данных клиентов, фискальных и товароучетных данных. Обладателем информации и оператором

является индивидуальный предприниматель. Ответственными за защиту информации в учебной модели являются владелец ИП и назначенный администратор или обслуживающий ИТ-подрядчик.

Описание системы как объекта защиты. Система не является государственной информационной системой и не рассматривается как значимый объект критической информационной инфраструктуры. В ней обрабатываются обычные персональные данные клиентов программы лояльности и доставки.

Возможные негативные последствия. Реализация угроз может привести к остановке продаж, нарушению передачи фискальных данных, искажению цен и остатков, утечке персональных данных клиентов, компрометации учетных записей сотрудников, финансовым потерям, штрафам, репутационному ущербу и необходимости восстановления учета из резервных копий.

Возможные объекты воздействия. Основными объектами воздействия являются кассовое ПО, онлайн-касса, товароучетная база, сайт заказа, личный кабинет клиента, АРМ сотрудников, маршрутизатор, Wi-Fi, каналы связи с банком и ОФД, резервные копии, журналы событий и учетные записи пользователей.

Источники угроз. Актуальными источниками являются внешний хакер, преступная группа, конкурент, клиент, сотрудник магазина, владелец или администратор при злоупотреблении правами, ИТ-подрядчик, поставщик облачных или коммуникационных услуг, бывший сотрудник и вредоносное ПО.

Способы реализации угроз. Нарушитель может использовать фишинг, подбор паролей, повторное использование скомпрометированных учетных данных, эксплуатацию web-уязвимостей, небезопасный удаленный доступ, ошибки настройки сетевого оборудования, заражение АРМ вредоносным ПО, неправомерную выгрузку отчетов, изменение конфигурации, отказ в обслуживании и доступ к резервным копиям.

Таблица 5 - Уровни возможностей нарушителей

Уровень	Актуальные субъекты	Возможности	Связанные угрозы
Н1	клиент, рядовой сотрудник, бывший сотрудник без действующих прав	использование штатного интерфейса, слабых паролей, ошибок бизнес-логики	УБИ.008, УБИ.031, УБИ.067, УБИ.068
Н2	внешний хакер, конкурент, подрядчик, разработчик	сканирование, фишинг, эксплуатация типовых web-уязвимостей, доступ к настройкам или коду	УБИ.006, УБИ.015, УБИ.016, УБИ.017, УБИ.033, УБИ.034
Н3	преступная группа, привилегированный администратор, провайдер инфраструктуры	комбинированная атака, обход контроля, изменение конфигурации, скрытое копирование базы	УБИ.007, УБИ.012, УБИ.023, УБИ.030, УБИ.069
Н4	специальные службы или государственно поддерживаемые группы	высокоресурсные целевые атаки и сложная компрометация цепочек поставки	для данного объекта не принимается как основной актуальный нарушитель

Вывод по модели нарушителя. Наиболее вероятный сценарий связан с внешним нарушителем уровня Н2-Н3: разведка публичных сервисов, фишинг сотрудника или эксплуатация уязвимости сайта заказа, получение первичного доступа, повышение привилегий, поиск конфигураций и выгрузок, копирование клиентской базы и попытка скрыть следы. Второй значимый сценарий связан с внутренним нарушителем уровня Н1-Н2: сотрудник или бывший сотрудник использует доступ к товароучетной системе, кассовому ПО или отчетам для неправомерного копирования данных либо изменения операций. Уровень Н4 зафиксирован как теоретически возможный, но для малого продовольственного магазина не считается основным при оценке актуальности угроз.

4. Дополнение моделирования угроз матрицами MITRE ATT&CK

Методика ФСТЭК России позволяет определить актуальные угрозы, объекты воздействия, источники угроз и негативные последствия. MITRE ATT&CK дополняет этот подход описанием тактик и техник поведения нарушителя. За счет этого модель угроз можно использовать не только для формального выбора УБИ, но и для построения сценариев атак, требований к журналированию, мониторингу, обнаружению и проверке защищенности.

Для объекта продовольственного магазина применима матрица MITRE ATT&CK Enterprise, поскольку атака может затрагивать рабочие станции, сервер учета, web-приложение, облачный сервис и каналы связи. Ниже приведен пример соответствия техник MITRE выбранным угрозам ФСТЭК.

Таблица 6 - Пример дополнения модели угроз техниками MITRE ATT&CK

Тактика MITRE	Техника	Проявление для объекта	Связь с УБИ
Reconnaissance	T1595 Active Scanning	поиск открытых сервисов сайта заказа, VPN, удаленного администрирования	УБИ.036, УБИ.037
Initial Access	T1190 Exploit Public-Facing Application	эксплуатация уязвимости формы заказа или API	УБИ.006, УБИ.033, УБИ.068
Initial Access	T1566 Phishing	письмо кассиру или владельцу ИП от имени банка, поставщика или ОФД	УБИ.008, УБИ.167
Credential Access	T1555 Credentials from Password Stores	получение сохраненных паролей с АРМ сотрудника	УБИ.008, УБИ.046
Persistence	T1505.003 Web Shell	размещение web-shell после компрометации сайта заказа	УБИ.023, УБИ.012
Privilege Escalation	T1068 Exploitation for Privilege Escalation	повышение прав на сервере или АРМ	УБИ.007, УБИ.031
Discovery	T1083 File and Directory Discovery	поиск выгрузок клиентов, резервных копий, конфигураций и ключей	УБИ.015, УБИ.016
Collection	T1005 Data from Local System	сбор базы клиентов, заказов, отчетов и документов поставщиков	УБИ.067
Exfiltration	T1041 Exfiltration Over C2 Channel	вывод архива данных через сетевой канал управления	УБИ.069
Impact	T1499 Endpoint Denial of Service	нарушение работы сайта заказа или кассового рабочего места	УБИ.014, УБИ.022

Заключение

В ходе лабораторной работы описана информационная система ИП «Продовольственный магазин» как объект защиты информации, определены ключевые активы, назначение и актуальность защиты. Выделены 23 актуальные угрозы из банка данных угроз ФСТЭК России, классифицированы характер происхождения угроз и источники их появления.

Сформирована модель нарушителя по структуре Приложения 3 к Методике ФСТЭК России. Для объекта наиболее актуальны внешние нарушители уровня Н2-Н3, внутренние пользователи уровня Н1-Н2, привилегированные администраторы и обслуживающие подрядчики уровня Н3.

Наиболее существенные сценарии связаны с компрометацией учетных данных, эксплуатацией web-уязвимостей, заражением рабочих мест, неправомерной выгрузкой ПДн, изменением конфигурации и нарушением доступности кассового или товароучетного контура.

Дополнение анализа матрицами MITRE ATT&CK делает модель более прикладной: выбранные угрозы связываются с конкретными тактиками и техниками атаки, что позволяет формировать требования к мониторингу, журналированию, обнаружению и проверке защищенности.